AUTONOMOUS MULTI-AGENT SECURITY PLATFORM

XBOW VISUAL DIRECTION • VERSION 2.4

AEGIS-AGENT Operational Runbook & Step-by-Step Guide

Complete step-by-step instructions for launching the system, configuring OpenRouter AI credentials, providing inputs, performing end-to-end security audits, and presenting to judges.

LOCAL RUNTIME URL `http://localhost:3000`	**API HEALTH CHECK** `http://localhost:3000/api/health`
AI REMEDIATION PROVIDER `OpenRouter (google/gemini-2.5-flash)`	**DATABASE PERSISTENCE** `PostgreSQL (Pooled) + Native SQLite`
AUTHORIZED SCOPE BOUNDS `Local training app (auth-service:v1.4.2)`	**EXECUTION ENVIRONMENT** `Native Node.js v24 (Zero external npm deps)`

Mandatory Scope Boundary & Prototype Notice:
This prototype is strictly bounded to explicitly authorized local sandbox fixtures. External public URL probing, unapproved code writes, and destructive exploits are disabled by design. All proposed code diffs require mandatory human-in-the-loop sign-off before application.

1. Quick Start & Server Launch

The AEGIS-AGENT platform runs natively on Node.js using built-in HTTP, native SQLite storage (`node:sqlite`), and native fetch. No complex build pipelines or external dependencies are required.

STEP 1.1 **Open Terminal in Project Root** PowerShell / Command Prompt

Navigate to the project root directory where `server.js` is located:

```
cd c:\Users\dell\Desktop\AfterHours
```

STEP 1.2 **Verify Environment Variables (.env)** Secrets Isolation

The server parses `.env` on boot. The key is never committed to Git (strictly ignored via `.gitignore`):

```
# Environment Settings (.env)
PORT=3000
APP_URL=http://localhost:3000
OPENROUTER_API_KEY=sk-or-v1-****************************************
OPENROUTER_BASE_URL=https://openrouter.ai/api/v1
OPENROUTER_MODEL=google/gemini-2.5-flash
DATABASE_URL=postgresql://postgres:postgres@localhost:5432/aegis_agent
```

Security Guarantee: The server blocks any direct web request to `/.env` with a `403 Forbidden` status code.

STEP 1.3 **Start the AEGIS Backend Server** Server Startup

Execute the start command:

```
npm start    # OR execute: node server.js
```

Confirm the terminal displays the startup banner:

```
📦 Database connected: Native SQLite storage at aegis_records.sqlite
🛡️  AEGIS-AGENT Security War Room running at http://localhost:3000
📡 Local Frontend: http://localhost:3000 | 🔌 Backend API: /api/runs
```

STEP 1.4 **Open the Web Interface** Browser Access

Open your browser and navigate to: **http://localhost:3000**

2. Step-by-Step UI Inputs & Execution Guide

Follow these exact operational steps to demonstrate every capability of the platform:

`WORKFLOW 1` **Landing Overview & AST Scanner Execution** — Primary Entry Point

Where: Top Navigation → `Overview` tab (or `http://localhost:3000#landing`)

User Action / Click	Input Details	Expected Visual Output
1. Inspect Hero Console	Click: `Attack Trace`, `AST Rules`, or `Security Memory`	Live terminal logs update in real-time with syntax highlighting.
2. Click "Run AST Scanner"	Button on the split hero section	Toast: "*Triggering local AST Semgrep scan...*". Transitions to Finding Detail.

`WORKFLOW 2` **Finding Detail & Live OpenRouter AI Synthesis** — P0 Remediation Synthesis

Where: Top Navigation → `Finding Detail` tab (or `http://localhost:3000#findingdetail`)

Field / Control	What to Select / Input	System Behavior
Select Finding Dropdown	Choose: `FIND-CWE89-01: SQL Injection in User Login`	Loads sanitized HTTP proof: `admin' OR 1=1--` returning `HTTP 200 OK`. Displays risk score 9.2 / 10.0.
OpenRouter Unified Diff	Review Candidate Fix Proposal panel	Displays real unified diff synthesized by **OpenRouter (google/gemini-2.5-flash)** replacing concatenated SQL with parameterized queries.
Human Approval Button	Click **"Approve Patch"**	Records approval in DB (`approval_records` table) and shows green confirmation: "*✓ Approved by operator.*"
Auditor Check Button	Click **"Run Auditor Check"**	Executes independent regression matrix. Shows toast: "*Auditor Agent: 4/4 checks passed*".
Export SARIF / JSON	Click **"Export SARIF / JSON"**	Downloads formatted JSON artifact containing vulnerability metadata and diff hash.

`WORKFLOW 3` **Interactive Multi-Stage Attack Path Visualizer** — P1 Attack Graph

Where: Top Navigation → `Attack Path` tab (or `http://localhost:3000#attackpath`)

Control	User Action	Expected Result
Attack Path Tabs	Click `CWE-89 SQLi`, `CWE-287 Auth Bypass`, or `CWE-22 Path Traversal`	Renders horizontal node graph with animated SVG dashed flows linking Entry → Vulnerable File → Impact Asset.
Graph Node Inspection	Click on `node-vuln` (Vulnerable Component)	Slides out the **Evidence Inspector Drawer** showing AST match rule and raw server reproduction trace.

3. Live War Room Synchronous Simulation

To demonstrate the 5-stage synchronous pipeline with bounded retries, state machine validation, and Sentinel gatekeeper alerts:

WORKFLOW 4

Initiating a Multi-Agent War Room Run

Live 5-Stage Orchestration

Where: Top Navigation → `War Room (Live)` tab → Click **"Start Demo Run"**

Modal Input Options:

Modal Input Field	Recommended Option	Alternative Paths
1. Authorized Target	`Local training app (auth-service:v1.4.2)`	Arbitrary public URLs are rejected server-side.
2. Security Test Case	`Input validation check (CWE-89)`	`CWE-287`, `CWE-22`, or `CWE-78`
3. Simulation Outcome	**Successful Pass (complete)**	• `Sentinel Alert (needs_review)` • `Regression Failure (failed)`
4. Scope Confirmation	Check **"I confirm scope authorization"**	*Mandatory — button disabled until checked.*
5. Action	Click **"Start Run"**	

What Happens Across the 5 Synchronous Stages:

Stage 1 (Scope Gatekeeper): Validates target against allowlist. Rejects out-of-scope targets instantly.

Stage 2 (Red Agent): Injects bounded payload `admin' OR 1=1--` against port 8080. Captures HTTP evidence.

Stage 3 (Sentinel Agent): Validates empirical response. Marks finding `CONFIRMED`. *(If Sentinel Alert selected, halts here for review).*

Stage 4 (Fix Agent): Prepares minimal candidate patch in isolated memory worktree. Requires human approval.

Stage 5 (Auditor Agent): Runs independent regression tests. Reports 4/4 checks passed.

WORKFLOW 5

Visual Theme Customization

UI Themes

Toggle visual themes anytime in the top navbar right-hand group:

- 🟢 **Cyber Lime (Default):** XBOW-inspired near-black (`#020708`) with acid-lime green (`#A3E635`) highlights.
- 🔴 **Red & Black:** High-contrast stealth operations crimson (`#E63946`) on obsidian black.
- 🏛️ **Warm Ivory:** Editorial print-inspired atelier theme with ivory paper and terracotta accents.

4. Direct REST API Testing Commands

To inspect or test the backend API directly via terminal or automated scripts, run these PowerShell commands:

API 1 — Health Check & Provider Status — `GET /api/health`

```
Invoke-RestMethod -Uri "http://localhost:3000/api/health"
```

```
{ "status": "ok", "database": { "connected": true, "provider": "sqlite" }, "ai_provider": { "configured": true, "model":
```

API 2 — Trigger OpenRouter AI Patch Synthesis — `POST /api/findings/:id/propose-fix`

```
Invoke-RestMethod -Uri "http://localhost:3000/api/findings/FIND-CWE89-01/propose-fix" `
  -Method Post -ContentType "application/json" -Body '{"scope_confirmed":true}'
```

```
{ "provider": "OpenRouter (google/gemini-2.5-flash)", "status": "PROPOSED", "changed_files": ["backend/services/auth_serv
```

API 3 — Record Human Governance Decision — `POST /api/proposals/:id/decision`

```
Invoke-RestMethod -Uri "http://localhost:3000/api/proposals/PROP-FIND-CWE89-01/decision" `
  -Method Post -ContentType "application/json" -Body '{"decision":"approved","reason":"Operator reviewed diff"}'
```

```
{ "status": "recorded", "proposal_id": "PROP-FIND-CWE89-01", "decision": "approved" }
```

API 4 — Execute Independent Regression Suite — `POST /api/findings/:id/regression`

```
Invoke-RestMethod -Uri "http://localhost:3000/api/findings/FIND-CWE89-01/regression" `
  -Method Post -ContentType "application/json" -Body '{"scope_confirmed":true}'
```

```
{ "status": "passed", "test_command": "pytest tests/security/test_login_regression.py", "total": 4, "passed": 4 }
```

5. How to Present to Judges (3-Minute Script)

Deliver these concise, high-impact points to highlight why AEGIS-AGENT stands out:

`TALKING POINT 1`

The Real Problem with AI in Cybersecurity

*"Most AI cybersecurity tools hallucinate targets, generate broken exploit code, and attempt to write unverified patches directly into production repositories. AEGIS-AGENT solves this through a rigorous **4-Stage Gatekeeper Model**."*

`TALKING POINT 2`

Empirical Evidence & Zero Unchecked Scans

*"Notice how our **Sentinel Agent** refuses to forward scanner alerts to the Fix Agent until it proves empirical reproduction via local HTTP boundary probes. Speculative scanner noise is filtered out before it ever wastes developer time."*

`TALKING POINT 3`

Isolated Worktree Diffs & Mandatory Human Approval

*"Our **Fix Agent** (powered by OpenRouter Gemini 2.5 Flash) proposes minimal unified diffs in temporary isolated worktrees. It never executes shell commands and never modifies user files without explicit human sign-off."*

`TALKING POINT 4`

Independent Auditor & Dual Verification

*"Finally, our **Auditor Agent** doesn't just ask the AI if the code is safe. It independently compiles and executes allowlisted test suites to prove that: (1) the exploit breaker payload is blocked, and (2) existing authenticated logins continue to work normally."*

Demonstration Acceptance Checklist:

- ✓ **Local Server Running:** Tested and live at `http://localhost:3000`.
- ✓ **OpenRouter API Connected:** Real patch synthesis via `google/gemini-2.5-flash`.
- ✓ **Secrets Fully Isolated:** `.env` ignored by Git; HTTP access returns `403 Forbidden`.
- ✓ **Database Persistence Active:** All runs, findings, and approvals persisted in SQLite.
- ✓ **Visual Design Complete:** Dynamic XBOW dark-cyber design with 3 switchable themes.